

Supplementary material for CONTAINER: Bounding Credential-Compromise Impact in IEEE 2030.5 DER Systems

Huan Bui

University of North Carolina at Charlotte, Charlotte, NC, USA

SM.1 Standards quotations supporting the claim matrix

The manuscript’s standards table cites a free source for each claim. This section reproduces the load-bearing text verbatim, so a reader can check the reading without obtaining any document that must be purchased. All quotations are from Sandia National Laboratories, *Recommendations for Trust and Encryption in DER Interoperability Standards*, SAND2019-1490, whose full text is publicly available from OSTI.

Certificate lifetime and revocation.. From §4.1:

“The IEEE 2030.5/CSIP PKI is different than other PKI’s in the use of non-expiring certificates and the explicit prohibition of CRL and OCSP. Once issued, a device certificate has an indefinite lifetime, so it is always valid. . . . If the device’s private key is compromised, the device certificate cannot be revoked. . . . In fact, IEEE 2030.5 prohibits their use. This means that Certificate Authorities (CA) shall not maintain CRLs or run OCSP servers, and clients and servers shall not check for CRLs or OCSP servers to verify certificate validity.”

Email address: `hbui11@charlotte.edu` (Huan Bui)

The prohibition is scoped, which is why the manuscript qualifies it. From §6.4, quoting the standard’s own certificate-management statements:

“The phrase ‘Optional OCSP’ means that the server device (and optionally, the client device) may utilize Online Certificate Status Protocol as an additional mechanism to determine if a certificate has been revoked. **OCSP may only be used to verify non-IEEE 2030.5 certificates.**”

Local allow/deny listing, and its limits.. From §4.1 and §4.1.2:

“This does not preclude servers or clients from maintaining or obtaining their own list of blacklisted or whitelisted devices if the operator prefers.”

“A blacklist is essentially a local CRL but without the process, rigor and verification behind its issuance.”

“With fragmented blacklists and policies, it is possible for a stolen device certificate that was disallowed in one region to be used in a different region to gain access because it was only locally blacklisted.”

A short-lived operational credential is permitted.. From §6.4:

“Inverter manufacturers strictly following these guidelines are **not required to limit the life of a device certificate** or to validate IEEE 2030.5 certificates using OCSP or CRLs.”

“(1 year certificate life is the usual recommended renewal interval).”

This is why the manuscript claims no novelty for the short lifetime itself: it is recommended practice in the analysis of record, and permitted rather than prohibited by the profile.

The adversary the design targets.. From §6.4:

“If a manufacturer decides not to implement certificate revocation and replacement, for a critical period an adversary could potentially extract a private key from a device and masquerade as the legitimate device without other nodes being aware of the device compromise.”

What no accessible source states.. Searched for and not found, in SAND2019-1490 or in the CSIP Implementation Guide: any statement that adding an identity to a deny list terminates that identity’s *established* mutual-TLS session; any statement that it cancels an already-issued `DERControl`; and any mechanism by which an authorization can bound the *value* a control may take rather than which function may be invoked. The first two are the premise of the manuscript’s containment argument, and the third is why its numeric authorization is placed above `FunctionSetAssignments` rather than inside it.

SM.2 The IEEE 9500 non-convergence, in full

The manuscript states that the PNNL 9500-node system did not converge in our build and therefore contributes no reported number. This section names the failure mode, so the absence is an explained negative result rather than a silent omission.

The failure is in the *base case*, with no attack and no PV of ours placed: the model’s own shipped driver, unaltered, returns `Converged = False` with an empty error description and every bus per-unit magnitude reading zero — the solution collapses rather than missing tolerance. It reproduces at 1000 iterations, under both the normal and Newton algorithms, and with feeder controls enabled and disabled, so it is neither a control-loop oscillation nor an iteration-budget shortfall. Our build is DSS C-API 0.14.5 / DSS-Python 0.15.7 / OpenDSSDirect.py 0.9.4 on macOS arm64.

We did not resolve it and we do not attribute it, having had no second OpenDSS build to discriminate a defect on our side from one in the model. The consequence is that the 9500 system supports nothing in the manuscript. Cross-feeder generality rests instead on the IEEE 8500-node and IEEE 123-bus feeders,

which every physical result in the paper uses, and which differ in voltage level, topology, regulator structure and stiffness.

SM.3 Inventory of the runs behind the manuscript

Table 1 inventories every run, so no experiment’s scale has to be inferred from prose. Seeds are paired across arms within an experiment. “Arms” counts independent feeder compiles; “solves” counts power-flow solutions, since an arm that searches an authorization set or steps a horizon contains many.

Table 1: Runs behind the manuscript. The calibration and the two post-hoc sweeps are labelled as such; neither supports a hypothesis test.

Experiment	Seeds	Arms	Solves	Status
Hosting-capacity calibration	5	560	1120	calibration
Authorization-shape sweep	20	2520	18000	confirmatory
Lifecycle horizon experiment	20	40	48000	confirmatory
Attacker action-space scan	20	60	2760	confirmatory
Reliance resolution sweep	20	160	1280	post-hoc
Lifecycle parameter sensitivity	—	60	—	post-hoc, model only
Credential-service invariants	1	10	—	confirmatory
Overhead microbenchmarks	500 iterations	4	—	confirmatory
Availability fault injection	3 policies	3	—	confirmatory

The authorization-shape sweep is 2 feeders $\times$ 3 penetration rungs $\times$ 11 authorization sets $\times$ 2 control primitives $\times$ 20 paired seeds, less the read-only set, which has no fixed-setpoint realisation. The lifecycle experiment is 2 operating states $\times$ 20 paired seeds $\times$ 19 lifecycle arms plus a paired legitimate arm, each stepped over a 60-minute horizon.

SM.4 Result files and the claims they support

Every numeral in the manuscript is checked against these files by `check_numbers.py`, which fails if a reported number cannot be located in them.

Table 2: Released result files and the manuscript claims each supports.

File	Supports
<code>hosting_capacity.json</code>	operating ladder, compliance criterion
<code>authz_shape.json</code>	authorization-set families, H1, H2, H3
<code>shape_contrasts.json</code>	paired H1/H2/H3 estimates and intervals
<code>reliance_resolution.json</code>	intermediate rungs of the reliance curve
<code>lifecycle_physical.json</code>	horizon time series, all lifecycle arms
<code>lifecycle_contrasts.json</code>	paired lifecycle contrasts, Holm-corrected
<code>lifecycle_sensitivity.json</code>	parameter sensitivity of the exposure window
<code>attackers.json</code>	five attacker models, full action-space scan
<code>attacker_detectors.json</code>	dual-detector analysis, dual-evading optimum
<code>retention.json</code>	compromise-class retention expectations
<code>credsvc.json</code>	the ten security invariants
<code>hwkey.json</code>	the failed hardware-keystore attempt
<code>controlmode.json</code>	feeder controls active under <code>static</code>
<code>availability.json</code>	safe-mode availability under verifier outage

SM.5 Impact accounting: notation, and why reachability alone cannot rank these designs

This section fixes the notation the body uses for the four quantities a credential compromise moves. It is *not* a contribution and the body does not claim it as one: an extended attack graph yields the same accounting and so agrees with this work rather than competing with it. It sits here rather than in the body because the body’s load-bearing quantities — the retained-authority components T_{cred} , T_{sess} and T_{cmd} — are defined where they are used, and the remaining notation is needed only by a reader who wants the general form.

This section fixes notation and says why we need it. As the introduction states, it is *not* a contribution: an extended attack graph [1, 2, 3] yields exactly the accounting below and so agrees with us rather than competing. We keep the notation only because the experiments in the manuscript’s results section move “how much”, “for how long”, and “under which grid conditions” differently,

and one scalar cannot express that.

Substrate and the four quantities. A static privilege graph $G = (V, E)$ has principals and resources as nodes and access relations as edges; $x \subseteq V$ is a set of compromised credentials, and a policy $\pi = (L, \text{Att}, A)$ gives a lifetime function L , an attestation-gated renewal predicate Att , and a scope map A . The device and grid state u_t and the feeder power-flow and protection model F appear nowhere in G , which is the point.

Cyber reach $\text{BR}_{\text{reach}} = \text{ReachSet}(x, \pi)$, a count, is the least fixed point of the π -enabled access relation from x : the endpoints the compromised authority can send an authenticated request to. *Commandable flexibility* BR_{flex} , in kW and kVAr, is the aggregate over reachable DERs of the feasible set-point region $\mathcal{C}_d(t; u_t, A_\pi(d))$ given irradiance, state of charge, and inverter limits; a read-only scope yields the current set-point alone, hence zero. *Retained authority* separates three durations, in seconds,

$$\text{BR}_{\text{auth}} = (T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}}), \quad (1)$$

where T_{cred} runs until the stolen credential is refused for a *new* session, T_{sess} until already-authenticated sessions can no longer issue commands, and T_{cmd} until queued or latched controls stop affecting the DER; the capacity-time exposure $\text{BR}_{\text{exp}} = \int \text{BR}_{\text{flex}}(t) \mathbf{1}[\text{authority effective}] dt$ carries kW·h or kVAr·h. **We report the vector and not its maximum.** A maximum is the obvious summary and it is the wrong one here: the three components are bounded by three different mechanisms, and collapsing them hides which one failed. the manuscript’s results section measures arms whose maxima are identical and whose components — and physical consequences — are not. Expiry bounds T_{cred} alone. *Physical consequence* $\text{BR}_{\text{phys}} = \max_a J_V(F, u, a)$ is the worst outcome reachable within the adversary’s authority, where J_V is the voltage-violation area outside the ANSI C84.1 band weighted by magnitude. BR_{phys} carries two units and we label every table with which: *p.u.-node* evaluated at one operating point, and *p.u.-node-min* accumulated over a horizon. Secondary metrics are maximum

per-unit deviation, violating-node count, protection-screen crossings, regulator tap operations, energy not served, unnecessary curtailment, and recovery time.

Three separations, true by construction.. Call a measurement *reachability-only* if it is a function M of $\text{ReachSet}(x)$ alone. Then, at fixed reachable set, varying the scope map changes BR_{flex} ; an attestation-gated ephemeral credential and a long-lived unrevoked one differ in BR_{auth} and BR_{exp} ; and the same authorized command is harmless at one operating state and crosses the IEEE 1547 over-voltage screen at another. **None of these can fail**, since M is single-valued in $\text{ReachSet}(x)$ and each construction varies a quantity that is by definition not an argument of M . They restate a definition. We keep them only because they say which quantities an evaluation must move, and each ships as a regression test in the released engine. **They are not evidence for the design; that is in the manuscript’s results section, and only there.**

SM.6 The cyber-side analysis engine

The engine computes the cyber-side quantities of SM.5 for a compromise locus under a policy. It supports no claim in the body’s results, which are physical; it is described here so the released artifact is documented.

We implement the cyber-side impact dimensions as an analysis engine, `pkimodel`, that computes BR_{reach} , BR_{flex} , and BR_{auth} for a compromise locus under a policy. The engine models the identity and delegation graph over the six node types of the threat model, with typed issuance, delegation, and authorization edges. Its central modeling choice follows the formalism: a credential’s reach (which DERs it can address) is represented independently of its scope (which function sets it may invoke at each DER). This is what makes the separating counterexample expressible in code, and we ship that counterexample as a regression test: the two compromises resolve to an identical reachable set of eleven DERs, yet the engine computes zero commandable kW for the attested credential against tens of MW for the legacy one, and a persistence of hours against the analysis horizon.

The authorization policy is parameterized, not fixed: a hardcoded permissive access model would overstate what a stolen certificate can command, so the engine exposes four ACL realism levels spanning single-device, site, feeder-segment, and whole-fleet scope, varied in the evaluation. On a synthetic 200-device fleet over four feeders the reachable-DER count grows from one (single-device and site) to fifty (feeder) to two hundred (fleet), with commandable capacity in step; the feeder-level figure is the fleet divided by the feeder count and moves with that parameter. This operationalizes RQ1: most reach gained by a compromise is attributable to authorization scope rather than to authentication alone. Retained authority is returned as a distribution over duration, not a point estimate, and separates credential, session, and command-effect components.

The engine consumes synthetic scenarios from a deterministic, seedable generator, since real utility authorization graphs are not public; the generator is released as part of the artifact. The engine is cyber-side only. It produces the reachable-DER set and the commandable-capacity envelope that the feeder simulation consumes to compute BR_{phys} .

References

- [1] N. Poolsappasit, R. Dewri, I. Ray, Dynamic security risk management using bayesian attack graphs, *IEEE Transactions on Dependable and Secure Computing* 9 (1) (2012) 61–74. doi:10.1109/TDSC.2011.34.
- [2] L. Wang, T. Islam, T. Long, A. Singhal, S. Jajodia, An attack graph-based probabilistic security metric, in: *Data and Applications Security XXII (DB-Sec 2008)*, Vol. 5094 of *Lecture Notes in Computer Science*, Springer, 2008, pp. 283–296. doi:10.1007/978-3-540-70567-3_22.
- [3] M. Frigault, L. Wang, Measuring network security using bayesian network-based attack graphs, in: *2008 32nd Annual IEEE International Computer Software and Applications Conference (COMPSAC)*, IEEE, 2008, pp. 698–703. doi:10.1109/COMPSAC.2008.88.